

Data Retention and Disposal Policy

Owner:	Bar Elezra, Head of Information Security
Contact:	security@pennylime.com
Effective date:	April 1, 2026
Last reviewed:	April 29, 2026
Review cadence:	Annual, or upon material change to applicable laws.
Public copy:	https://pennylime.com/security/data-retention
Parent policy:	Information Security Policy (https://pennylime.com/security)

This Data Retention and Disposal Policy defines how long PennyLime retains different categories of information, the legal and regulatory bases for those retention periods, the methods by which data is securely disposed of when retention windows end, and the rights consumers have to request access, correction, or deletion. It supplements the parent Information Security Policy and is binding on all personnel and service providers.

1. Purpose and Scope

This policy applies to all PennyLime information assets including merchant applicant data, customer financial data, identity documents, Plaid-derived bank data, payment records, audit logs, marketing communications, and business records. It governs primary production storage, backups, archives, and copies held by service providers.

2. Guiding Principles

- **Purpose limitation.** Data is retained only as long as a legitimate operational, legal, regulatory, or contractual purpose exists.
- **Minimum necessary.** Where multiple retention windows could apply, the shortest window that satisfies all obligations is used.
- **Secure disposal.** When a retention window ends, data is securely destroyed using methods appropriate to the storage medium and the data classification.
- **Documented exceptions.** Legal holds, active investigations, and audit-driven extensions are documented and tracked to release.

3. Roles and Responsibilities

The Head of Information Security owns this policy, the retention schedule, and the disposal procedures. Personnel are responsible for following the schedule for data they create or access. Service providers handling customer data are bound by written agreements requiring equivalent retention and disposal practices.

4. Retention Schedule

Data Category	Retention Period	Basis
Merchant application records (approved or declined): legal name, EIN, contact, application data	7 years from final decision or close of advance	BSA recordkeeping; state lending and licensing record requirements
Identity and KYC documentation: government ID, beneficial-owner records, OFAC screening results	5 years from termination of customer relationship	BSA / 31 CFR 1010.430
Funded advance and loan records: contracts, receipts, payment schedules, remittance history, payoff records	7 years from final payment or charge-off	State lending laws; tax / accounting requirements
Plaid access tokens (encrypted)	Active for the life of the account connection; revoked and removed within 30 days of customer relationship end or upon explicit revocation	GLBA Safeguards Rule; minimum-necessary principle
Plaid-derived transaction and balance data used in underwriting	7 years from final decision or close of advance, retained as part of the application file	Audit trail for underwriting decisions; ECOA Reg B (12 CFR 1002.12)
Adverse action notices and supporting consumer-report data	25 months from notice date	ECOA / Regulation B 12 CFR 1002.12(b)
Marketing leads (no application started)	24 months from last interaction, then deleted; sooner upon opt-out request	CCPA/CPRA; CAN-SPAM
Email and SMS communications log	18 months	Operational support; CAN-SPAM / TCPA documentation
SMS opt-in / opt-out records	5 years from last consent or revocation event	TCPA defense; Reg F
Audit logs (authentication, admin actions, sensitive data access)	12 months minimum; 7 years for events involving Restricted data or security incidents	Internal audit; incident-investigation needs
Tax, accounting, and corporate records	7 years	IRS recordkeeping
Vendor contracts and security reviews	Term of contract plus 7 years	Contract enforcement; vendor risk audit trail
Backups	Rolling 30 days unless covered by a longer retention requirement above	Disaster-recovery SLA; minimization

5. Disposal Methods

- **Database records.** Hard delete (DELETE statement) followed by verification. Where soft delete is used during a transition window, records are purged on a scheduled basis no later than 30 days after the soft

delete.

- **Encrypted fields with separate keys.** Cryptographic erasure (key destruction) is used where the field-level encryption key is held independently of the underlying storage.
- **Files and documents.** Overwritten and deleted from object storage; equivalent secure-delete operations performed on any local working copies.
- **Backups.** Backups containing data subject to a deletion request expire on the rolling 30-day window; backup-restoration procedures include re-application of any pending deletions.
- **Physical media (laptops, drives at decommission).** Full-disk encryption keys are destroyed and the device is securely wiped using a manufacturer-approved erase before reuse, transfer, or disposal.

6. Customer Rights

Consumers may request access to, correction of, or deletion of their personal information by contacting info@pennylime.com. Requests are verified and answered within 45 days, extendable to 90 days where reasonably necessary, in accordance with the CCPA/CPRA and other applicable state privacy laws. Where a deletion request conflicts with a regulatory retention obligation (e.g., BSA, Reg B records), the regulated data is retained for the required period and the consumer is informed; non-regulated personal information is deleted.

7. Legal Holds

Upon notice of pending or anticipated litigation, regulatory inquiry, or government investigation, applicable data is placed under legal hold and excluded from routine disposal until the hold is released by the Head of Information Security or designated counsel. Legal holds are documented with scope, custodians, and release date.

8. Service Provider Data

Service providers handling customer data are contractually required to maintain retention and disposal practices substantively equivalent to this policy and to certify destruction or return of customer data upon contract termination. The Vendor Risk Register (maintained by the Head of InfoSec) tracks each provider's deletion commitment.

9. Audit and Verification

The Head of Information Security verifies adherence to this policy at least annually. Verification includes sampling of expired records to confirm deletion, review of the disposal log, and confirmation of vendor-side destruction certifications. Findings are tracked to remediation.

10. Policy Review and Acknowledgment

This policy is reviewed at least annually, or sooner upon material change to applicable laws or business operations. Personnel acknowledge this policy at hire and at each annual review.